

SignalBridge

Your project handoff and interview field guide

A local security workbench that connects application access-control observations, detection rules, investigation decisions and test evidence.

Prepared for Aman Agarwal | September 30, 2026 | Evidence reviewed through September 29. This is your study and presentation guide, not an independent security audit or certification of your personal proficiency.

Your 30-second explanation

SignalBridge is my AI-assisted access-control monitoring project. It collects signed application metadata, applies explicit detection rules, and lets an analyst inspect the evidence and record a decision. Recorded isolated labs connect it to Wazuh and OWASP ZAP. The latest local work adds membership-removal correlation and an evaluation that reports false alerts and misses. It is a working proof of concept, with clear limits rather than an enterprise replacement.

1,102

automated tests passed

64 / 64

Wazuh batch delivered

22

evaluation scenarios

75%

precision and recall*

*On the selected builder-authored dataset only: six true positives, two false positives, two misses and eight true negatives. Four inconclusive cases are excluded. Test counts, delivery counts and detection accuracy measure different things. [S01-S03]

The central security question

After a person's access is removed, can their existing session still retrieve a known private record? Identity can remain valid while authorization must change. SignalBridge helps test, observe and investigate that boundary; the source application must enforce it.

Read pages 1-3 and 13-18 before a recruiter call. Use pages 4-12 and 19-20 for technical follow-ups. Rehearse page 21. Complete page 22 yourself before presenting an analyst work sample.

The September 29 enhancements are in the local public checkout. They were not deployed into the older working console or published in the preceding development turn. This handoff does not recheck running services or online deployment status.

What exists, and where

Use this status map to avoid presenting a plan, a test fixture or an old receipt as a live integration. The inspected public checkout is based on Git revision 6015801, with local uncommitted September 29 improvements. A Git revision alone does not identify those added working-tree bytes.

Item	Verified scope / current boundary
Public checkout	signalbridge-public contains the shareable source, historical receipts, static viewer and new R3/evaluation work. New changes remain local at this handoff.
Original development checkout	signalbridge contains the earlier local console, private operator artifacts and fuller historical guides. It was not upgraded by the September 29 change.
Console	Django application intended for loopback on one trusted machine. This document does not certify that it is running now.
Wazuh and ZAP	Real tools executed in bounded historical labs. Their receipts can be reviewed without starting them. Continuous service connections are not established.
R3	Implemented and tested through signed in-process ingestion and the worker. No native source adapter was enabled for its new membership assertions.
Shuffle	Preparation and image checks exist; no successful native workflow. Deferred after storage readiness failure.
Your analyst competence	Not established by code tests, AI reference answers or builder QA practice attempts. It needs your own explanation and reviewed work.

Find the material you need

Paths below are relative to **signalbridge-public**. This PDF lives at **output/pdf/SignalBridge_Recruiter_Handoff.pdf**. Keep the repository beside it for linked source references.

Use	Location / reading route
Actual integration evidence	portfolio/index.html - the retained Wazuh records and ZAP failure/retry
New evaluation and learning	portfolio/evaluation.html - all 22 outcomes and five AI-authored reference reviews
Technical explanation	docs/DESIGN.md and SECURITY.md
Exact receipts	docs/evidence/ - use the evidence index on page 24
Interview study route	Purpose 3; architecture 4; controls 5-8; integrations 9-12; metrics 13-14; stories 15; limits 16; ownership 17; questions 18-20; practice 21-22

Earlier PDFs in the private checkout remain historical. For the latest R3/evaluation claims, use this handoff and the September 29 receipts. Neither a static page nor an imported receipt proves a service is currently connected.

The business problem

A company needs confidence that private information stays private when membership, permissions or software changes.

An access rule written in a specification is not enough. Someone must test it, collect useful observations, investigate suspicious results and preserve evidence of any correction. SignalBridge brings those activities into one local workbench, using BetTail and Netted as application examples.

Requirement	How the project addresses it	What still needs judgment
Private resources are restricted	Selected positive and negative application tests; scoped evidence imports	Whether the tested identities and paths represent the business requirement
Observations have attributable origin	HMAC authentication, closed event schema, key-bound app/environment/source	Whether the instrumented source observed the result correctly
Suspicious patterns are reviewable	R1-R3 cases linked to exact observations and source identity	Whether a matched pattern is malicious, benign or inconclusive
Changes remain accountable	Versioned cases, audit entries, reviewer separation and retest evidence	Whether remediation actually addressed the cause
Claims can be checked	Retained execution receipts, hashes and a static evidence viewer	Whether the evidence is current and adequate for the proposed use

The end-to-end story

Requirement: a removed member must lose access to a known private resource. **Check:** compare member, removed-member and legitimate-owner behavior. **Observation:** collect narrowly scoped metadata. **Detection:** decide whether an explicit rule matches. **Investigation:** inspect evidence and alternatives. **Correction:** change the source permission boundary if a defect is established. **Retest:** show denial and legitimate access still work.

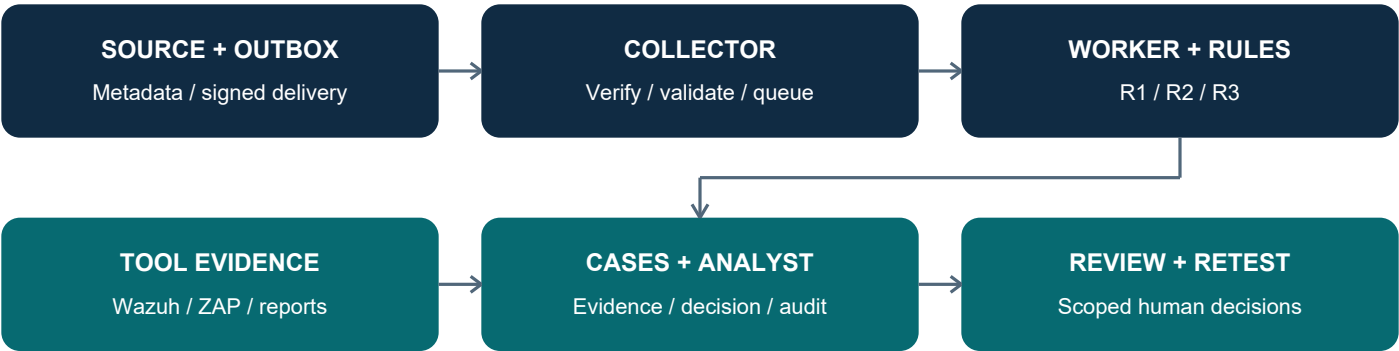
Business value you may describe

The intended value is traceable security assurance: less ambiguity between an alert, a failed test and a confirmed problem. An application owner and security analyst can discuss the same evidence. The project has not measured labor savings, return on investment, prevented incidents, adoption or production business impact.

SignalBridge does not sit in the user's request path to block access. Monitoring and test evidence help identify a failure; the application or its database/storage policies enforce the permission.

Primary roles are application owner, analyst, reviewer and local operator. This is a small local proof of concept, not a deployed multi-customer SOC platform. [S11-S12]

How the pieces fit together



The arrows describe implemented component paths. They do not mean every source application is continuously instrumented. External-tool execution is separately bounded and operator initiated.

Component	Implementation and reason for it
Source + courier	Node.js outbox signs metadata and retains undelivered files. Exact local destination, no redirects, bounded responses and retries.
Collector	Django ingestion verifies the signature, validates schema and scope, checks identity/rate limits, then commits a queued event.
Worker + detector	Python processes pending events, correlates R1-R3 and attaches evidence to investigations. Repeated failure is visible in dead-letter state.
Storage + console	SQLite, Django ORM/templates and Waitress. App-scoped cases, scanner findings, authorization checks, replay and private practice.
Optional tool paths	A local ledger hands sanitized records to a bounded Wazuh replay. Reviewed scanner reports and execution receipts feed findings/evidence.
Presentation	Static HTML evidence viewer with native expandable details; portable for review without installing the console.

Why these choices are reasonable here

Django supplies sessions, CSRF, ORM and template mechanisms. SQLite keeps the lab small; explicit Python rules are inspectable. A no-script interface reduces browser complexity. These choices suit a local project; production scale, PostgreSQL concurrency and failover are not demonstrated.

Recorded versions: Django 5.2.17, Waitress 3.0.2, Node 24+, Wazuh 4.14.8 and ZAP 2.17.0. PGLite supports earlier portable SQL checks. These are project versions, not claims about the latest releases.

Trace bridge/ingestion.py, worker.py, engine.py and views.py. Runtime decisions use rules; the core requires no ongoing AI API connection. [S11-S12]

What makes an event trustworthy?

Attributable is not automatically true. A valid HMAC establishes that a holder of the configured shared key signed particular bytes. It cannot establish that the source was uncompromised, correctly instrumented or describing the right business context.

Control	What it does / does not prove
HMAC-SHA-256	Signs the version prefix, app, key ID, request timestamp and exact body. Constant-time comparison protects signature checking. This is authentication/integrity, not encryption or public-key nonrepudiation.
Time + replay handling	Signed request time must be within five minutes. Event time permits seven days of delayed delivery and at most 60 seconds in the future. Same app/event ID plus identical content is a duplicate; conflicting content gets 409.
Closed schema	16 KiB maximum; required/allowed fields, canonical UUIDs, pseudonymous 64-hex actor/resource IDs and closed observation lists. Duplicate JSON keys and non-finite numbers fail.
Source and scope	App credential and environment are checked. Source class is assigned by the collector from the key, not accepted as a caller-controlled wire field.
Membership assertions	V2 adds subject/state for one exact resource. Only a key explicitly granted can_assert_membership may send them. Default is false, with a transaction-time permission recheck.
Rate and resource bounds	600 new events per app per minute; finite response/body limits and correlation caps. A limit prevents unbounded work; it does not establish production throughput.

Privacy and limitations

No wire fields are provided for raw names, emails, IPs, tokens or record contents. Pseudonyms can still be linkable, and metadata needs access control. A closed schema reduces accidental disclosure; it is not a guarantee that a malicious sender cannot encode information. Wazuh export reduces fields further and omits actor/resource identifiers.

Local HTTP is intentionally loopback-only. HMAC does not hide traffic from someone controlling the machine. The host, database administrator and signing-key holders are trust boundaries. Audit/source hashes check consistency; they are not a tamper-proof external witness.

Interview distinction: a SHA-256 digest can reveal changed content when compared with a trusted original. HMAC adds a secret-key check. Neither proves the business statement inside the event.

Implementation: bridge/contract.py, bridge/ingestion.py, integrations/sender.mjs. [S01, S11]

The three detection rules

Rule	Trigger	Interpretation and blind spot
R1 / medium	Three distinct private resources denied or not visible for one actor, app, environment and source in an inclusive five-minute rolling window.	Review repeated failures. Stale links can look similar. Same-resource repeats do not qualify; slow or distributed probing may be missed.
R2 / critical	An allowed private read whose source reason is membership_removed or policy_regression.	Prioritize a source-reported boundary failure. It depends on that label; it does not infer removal from another event.
R3 / high	Latest matching v2 membership assertion says removed, strictly before an allowed read and within 24 hours, for the affected subject and exact resource.	Correlate two observations without a suspicious read label. Missing grants, alternate rights and clock errors can still create false alerts.

Details a technical interviewer may test

- R1 window versus case:** qualifying endpoints are grouped into fixed UTC five-minute buckets. A case can combine overlapping qualifying windows, so its evidence may span more than five minutes. Late arrivals examine surrounding event time; episode changes do not reset the actor's live rule window.
- R3 identity:** the operator on a membership-change event may be an administrator. The affected account is membership.subject; that value must match the later read's actor. Resource, app, environment and collector source must also agree.
- R3 correction:** a newer effective grant suppresses the removal match. Simultaneous/conflicting state does not establish order. A delayed contradictory grant updates an existing case to medium-priority reassessment, adds evidence and reopens it while preserving its original audit entry.
- Scope:** R3 uses a 24-hour horizon and one resource, not a global revocation or group-to-resource expansion. More than 10,000 relevant records triggers visible capacity failure rather than silently truncating evidence. Native v2 adapters remain unfinished.

Severity expresses review urgency. It is not an exploitability score, a probability of attack, or proof that data was disclosed. A rule match starts an investigation.

SignalBridge's R1-R3 are distinct from Wazuh's custom rule IDs. Their input fields and logic are different. [S02-S03, S11]

Explain an access-after-removal case

This example follows executed synthetic scenario E01. It is not a discovered production incident or a claim that Aman personally performed this investigation. [S02]

Event time	Observed metadata	What it supports
t = 0	Credential-authorized membership.change: operator C removes subject A from resource B.	A separate assertion describes a permission change for A/B.
t = 7 seconds	A reads B; outcome allowed; reason member.	The source reports successful access after the recorded removal.
Processing	R3 creates a high-priority case linking both observations.	The implemented correlation condition matches. Actual content and alternate rights still need checking.

A useful analyst note has four parts

Observation: identify the two records and their order, scope and source. **Interpretation:** the sequence suggests an access boundary may have failed. **Uncertainty:** verify missing grants, owner/admin rights, clocks and whether private content actually returned. **Handoff:** ask the application owner to reproduce the same identity/resource case with a legitimate-owner control and preserve results.

Three variations change the conclusion

- E18, late grant:** a grant effective at t=3 arrives after the read. The original alert is retained and the case is reopened for reassessment. Event time and arrival order are not interchangeable.
- E19, service failure:** outcome error / dependency_unavailable does not show an allowed read or a correct denial. Restore the authorized lab dependency and repeat the check. Calling this safe would convert an outage into false assurance.
- E17, missing grant:** the declared benign story contains a re-grant that is absent from telemetry. Visible removal/read observations resemble E01, so the detector alerts. The missing fact cannot be inferred from a signature or a higher severity.

If a still-valid session returns HTTP 200 with the known private record after effective removal, that establishes that specific read under those test conditions. It does not establish write access, other resources, malicious intent or a production breach. Verify identity, effective policy and alternate authorization before escalation.

If the defect is confirmed, fix current authorization at the source boundary, then retest the removed member, authorized owner and restoration. A proposed retest is not completed remediation.

Use the console as an analyst

Screen	What to do there
Overview / Integrations	Select the intended app. Read source, coverage, delivery and historical receipt status before drawing conclusions.
Events / Detections	Inspect operation, outcome, reason, timestamps and provenance. Read each rule's trigger, limits and validation steps.
Investigations	Expand linked evidence, compare current rule and recorded generation, add rationale, and choose a scoped disposition.
Authorization checks	Review exact test paths, expected actors, positive/negative controls and restoration. A coverage matrix is not an app-wide percentage.
Scans / Findings	Separate tool-reported findings, execution evidence and your decision. Missing findings in a later report do not prove a fix.
Replay / Practice	Replay is advisory policy comparison. Practice is private learning with versioned drafts, submitted-answer locks and exports.

The application protects the review process

App memberships restrict lists, objects, exports and writes. Viewers read; analysts investigate and propose; reviewers can decide another person's replay proposal. Superuser status gives no implicit app bypass. Private practice attempts remain owner-scoped, including against another reviewer.

Writes refresh the account and app role inside a transaction before using the scoped object. Case decisions use versions and evidence digests; new evidence can reopen a closed case. Duplicate observations do not justify silently increasing case counts. Audit records preserve application history, subject to the trusted administrator boundary.

Sessions last one hour. HttpOnly and SameSite=Strict cookies, CSRF protection, login throttling and a no-script CSP reduce common browser risks. The Secure cookie flag, HTTPS redirect and HSTS apply outside local mode; their presence is not approval or proof of a production deployment.

For a practice report, reveal the evidence, then write Observation, Interpretation, Uncertainty and Handoff in your own words. Cite at least two revealed items; save before navigating. Submission locks the answer and reveals coaching. Declare authorship and AI/human assistance accurately.

Practice supports five fictional tabletop exercises plus recorded Wazuh/ZAP assignments. It does not create operational alerts or count as independently reviewed analyst competence. A second demo account is not a second human reviewer. [S11-S12]

What was tested in the source apps?

The project began with portable database checks, then added genuine local BetTail service and application-route evidence. Those layers must stay distinct. A stronger result from BetTail does not transfer to Netted.

Layer	Recorded work	Important limit
Portable SQL checks	BetTail: 68 migrations; Netted: 16. PGlite-based checks used simplified Supabase catalog substitutes.	Not genuine JWT login, network HTTP, storage service or full application coverage.
BetTail services	32 steps: 18 assertions, 10 setup, four restoration; genuine local auth, REST/storage paths in the isolated lab.	Selected synthetic users/resources. Steps are not all independent security assertions.
BetTail routes	23 steps: 16 assertions, four setup, three restoration against copied Next development routes /api/state and /api/chat-image.	Not all routes, source features, signed-URL behavior or production configuration.
Repair retest	The selected 16 route and 18 service assertions passed again after approved lab hardening, with separate restoration checks.	A scoped retest does not complete the original full integration gate.

The strongest concrete access story

A legitimate member could read known state/image data. After membership removal, the unchanged session still authenticated, while the former member's state request was denied and the image was not visible. The legitimate owner could still read the same data. Restoring membership restored positive access. This separates authentication, authorization and broken-service explanations. [S06-S07]

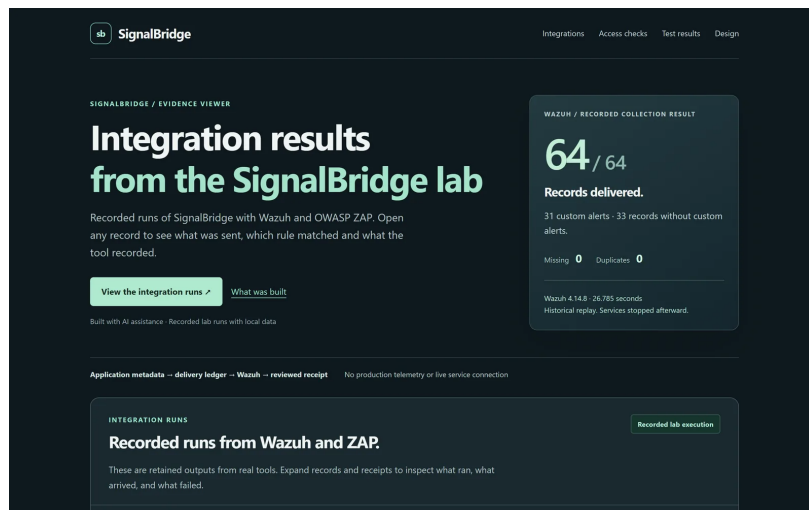
A 404 by itself does not prove a secure denial: the resource could be missing. Known-resource checks and the owner's successful read supply the necessary context. A 503 is inconclusive, not a denial. Setup and restoration results remain separate from the access assertions.

What you must not imply

There is no established production BetTail breach. The initial removed-member leak was a proposed demonstration; controlled mock responses later tested harness sensitivity. The full M1 gate remains explicitly incomplete, including broader routes, instrumentation and signed-URL conditions. Netted has no equivalent genuine HTTP/storage result in the reviewed evidence.

Source snapshots and run digests preserve the exact tested copies, including disclosed dirty-source state. Do not substitute today's working source for yesterday's recorded execution. [S06-S07, S12]

Wazuh: what integration really means



Retained public evidence-viewer image, not a current live-service screenshot. Its counts describe one bounded replay. [S03]

SignalBridge stages sanitized metadata in a recoverable local ledger/file. A separate operator-run controller snapshots the committed batch, waits for the real Wazuh collector, replays into a fresh bounded manager container, reconciles archive/alert records and imports a reviewed receipt.

Recorded result: Wazuh 4.14.8 received 64/64 records: 31 expected custom alerts, 33 records without custom alerts, zero missing or duplicate copies, in a 26.785-second run. The batch included 14 migration-lab, 24 synthetic and 26 unclassified legacy records.

The custom rules are deliberately narrow

A parent JSON rule gates the export contract. Child rules distinguish reported revocation/regression, denied reads, not-visible reads and dependency errors. Source class changes interpretation and level. The observed 31 alerts are not 31 vulnerabilities; a denied-read alert may reflect successful enforcement. Non-alerts are not automatically benign.

The export omits actor/resource identifiers, so Wazuh cannot reproduce SignalBridge's R1 distinct-resource correlation from it. R3 has not been carried into this native pilot. The project does not demonstrate a full Wazuh indexer/dashboard, host monitoring or a continuously reconciled integration.

The defensible claim is: this exact batch reached the real tool and produced the expected narrow rule outputs. Delivery completeness is not general detection accuracy or exactly-once delivery across all future runs.

ZAP and scanner findings

Real ZAP execution, deliberately limited

ZAP 2.17.0 ran in safe mode with passive analysis against a fixed synthetic fixture: exactly three GET paths, /, /login/ and /health/. Two paths supplied missing-header positives and one a clean control. Five findings across three rules were retained. Visiting a path named /login/ is not an authenticated login test. [S05]

Exercise	Recorded observation	Correct interpretation
Target unavailable	Zero accepted target requests; scan failed; coverage incomplete; 16.403 seconds.	The scan did not establish a clean application. The failure-handling exercise can pass while the scan fails.
Separate retry	Three GETs, five findings; positive and negative controls passed; 20.619 seconds.	The fixed fixture was scanned successfully within its narrow scope. This is not remediation of an application vulnerability.
Receipt import	Two execution receipts and two audit entries imported; repeated imports added no duplicate receipts.	Preserves real execution evidence. It does not start a tool or make the source continuously monitored.

Other implemented report paths

Strict adapters accept a supported subset of SARIF 2.1.0, pip-audit object JSON and fixed-fixture ZAP JSON. Local Ruff checks and explicitly requested package-advisory queries are available. These are parser/runner capabilities, not evidence that every tool producing SARIF has been integrated or independently evaluated.

Imports reject unsupported shapes and unsafe paths, bound report size/depth/counts and discard snippets, arbitrary messages, raw HTTP content and links. A skipped package scan means incomplete coverage. Suggested fixed versions are information, not automatic upgrades. SARIF severity is a tool level; pip-audit severity may remain unknown.

Finding, execution and analyst decision are separate: a report says what a scanner claimed; a receipt can establish what ran; a reviewed decision explains what it means. No finding in a later, narrower report does not prove that the original issue was fixed.

Do not claim active exploitation, authenticated scanning, crawling or comprehensive source-app testing from the ZAP pilot. No current Semgrep, Trivy, commercial XSIAM or Wiz connection is established by generic report support. [S05, S11-S12]

Reliability, recovery and lab safety

Mechanism	Recorded behavior / boundary
Courier and queue	Files persist pending delivery; a matching receipt is required before removal. Courier gives up into retained dead state after eight attempts. Worker uses five failed processing attempts before dead state. These are different retry layers.
Delivery ledger	Committed batches precede file publication; prefix/pending bytes are checked and fsynced before checkpointing. A 16 MiB stream cap stops growth. No automatic rotation/pruning policy is complete.
Wazuh recovery	Seven synthetic inputs, four expected alerts and three controls across four phases; two graceful collector restarts, split-line completion and rotation while stopped. No duplicates in that bounded observation.
Local backup drill	764 database rows and 18,263 delivery bytes verified in a separate writable restore. Working logical data remained unchanged; the live database was not replaced.

Isolation was part of the engineering work

Labs used synthetic identities, copied source, dedicated containers/networks, finite time and resource budgets, and pre/post checks. The Wazuh pilot used no network or published ports. ZAP and its target used an internal network with no published ports. The offline evaluation blocks network/process operations and uses memory-only SQLite; it is a trusted harness, not an OS sandbox for hostile code.

An approved BetTail repair replaced six services, preserved originals/data, removed backend host bindings and limited eight services to 4,256 MiB RAM and 5.75 CPU quota, without swap or automatic restart. Eight database roles passed 32 password checks; selected service/route retests and membership restoration passed. Five configuration restores were verified; two service-volume backup restores were not. [S07]

The limits that matter

There is no multi-day native soak, host power-loss proof, full-manager restart test, multi-node availability or PostgreSQL concurrency validation. Local administrators remain trusted. Current service shutdown state was not checked for this document; receipts describe the end state of their own runs.

Retention previews before deletion and targets only processed, unlinked events older than 90 days. Cases, audits, pending/dead events and ledger-linked evidence remain. Stale outbox locks or unexplained file changes require investigation, not deletion of evidence. [S04, S08, S11]

The numbers you can defend

Measure	Recorded result	Do not turn it into...
Sept. 29 software verification	1,102 tests: 1,048 Python + 54 mocked Node; zero failures/skips; 11 check groups passed.	1,102 attacks stopped, vulnerabilities found or live integration tests.
Frozen detection evaluation	22 scenarios / 52 deliveries: TP 6, FP 2, FN 2, TN 8; four inconclusive. Precision 6/8, recall 6/8, false-positive rate 2/10.	Production accuracy, a blind benchmark or superiority to another product.
Wazuh batch	64/64 received; 31 expected custom alerts, 33 non-alerts; no missing/duplicates in that run.	31 confirmed incidents, universal losslessness or detection precision.
ZAP retry	Three GETs / five findings; two header-positive paths and one negative control.	Five confirmed vulnerabilities in BetTail or an authenticated app scan.
BetTail routes	16 assertions, four setup and three restoration steps; 23 total.	23 independent security assertions or complete application coverage.
BetTail services	18 assertions, 10 setup and four restoration steps; 32 total.	32 vulnerabilities prevented or equivalent coverage in Netted.
Historical development set	15/15 scenarios; TP 5/FN 0/FP 0/TN 10; 600 benign events without alerts.	Enterprise load testing or evidence the newer evaluation should also be perfect.
Historical challenge	16/16 rule contracts met; 0/3 broader capability probes alerted.	19/19 detection capabilities passed.

Every row has a different denominator and some checks overlap. Never sum them into a single coverage score. A test can correctly pass because a negative control did not alert. A successful failure-handling test can contain an intentionally failed scan.

Evidence identity

The latest verification records a 264-file source manifest, unchanged during execution, SHA-256 **243a4dbe...303a5cf**. Full hashes and run identifiers are in the receipt. The working tree was dirty; the receipt binds tested source, not just its base Git commit. Documentation-only handoff work does not claim a new software execution.

Native tool receipts bind their own packages/runs. Historical September 26 verification was 1,083 tests, not today's 1,102. Preserve the old result instead of editing it to appear current. [S01-S09]

Understand the 75% result

The implementation was frozen, then a separate 22-scenario corpus was authored and sealed before execution. Predictions came from signed in-process collector requests and the actual queue/worker. Labels were joined after predictions. This separation reduces label leakage into rule execution; the author still knew the rules, so it is not a blind or independent assessment.

Declared scenario truth	Current detection	No current detection	Total
Suspicious	6 true positives	2 false negatives	8
Benign	2 false positives	8 true negatives	10
Inconclusive	Reported separately	Excluded from scoring	4

Precision = $TP / (TP + FP) = 6 / 8 = 75\%$. Of the scenarios that alerted, how many were declared suspicious?
Recall = $TP / (TP + FN) = 6 / 8 = 75\%$. Of the declared suspicious scenarios, how many alerted?
False-positive rate = $FP / (FP + TN) = 2 / 10 = 20\%$. Zero denominators are undefined, not automatically perfect.

Explain the failures, not just the percentage

Misses: E07 spreads probing over six minutes, outside R1's window. E08 distributes reads across accounts.
False alerts: E16 is legitimate stale-bookmark activity; E17 loses a re-grant event. **Inconclusive:** service failure, equal-time ordering, conflicting assertions and legacy metadata without the affected-member relationship.

E18 first alerts and then receives a delayed grant. The final state is corrected and the historical alert is retained. Final-state precision does not capture all analyst interruption cost; measure initial alert churn and time to correction separately in a future reliability study.

Why the project is stronger despite imperfect scores

The result makes limitations testable. Broadening a rule may improve recall while increasing false alerts. More independent benign activity, externally authored scenarios and prospective frozen-rule testing would make claims more credible. The small hand-selected class balance does not estimate real-world prevalence or give precise population performance.

Useful interview answer: I can show exactly what this dataset measures, explain the two misses and two false alerts, and describe the next experiment. I cannot claim 75% accuracy for enterprise traffic.

R3 covers richer new inputs; it does not change the original challenge's missing-context result. A signature cannot supply a fact the telemetry omitted. [S02, S09]

Three engineering stories worth learning

1. Permission withdrawn during a request

Problem: a case write could use an earlier permission check after the user's role or active state changed. Four controlled denial cases still advanced the case version; a legitimate control passed. **Change:** refresh current app membership/account state inside the write transaction, before locking the scoped object. Apply that guard to cases, replay, scanner workflows and private practice.

Verification: 13 regression tests covered withdrawn roles, removed membership, disabled accounts, scope changes and legitimate writes. An intermediate query error was retained and corrected. **Limit:** deterministic SQLite boundary tests are not a demonstrated PostgreSQL timing exploit or real incident. [S10]

2. A collector that started at the wrong point

Problem: an earlier fresh Wazuh collector attempt did not collect the intended backfill; EOF/readiness behavior mattered. **Change:** wait for the real collector to be ready, then replay the exact snapshot into its fresh spool. Do not manufacture a saved checkpoint. **Verification:** reconcile the 64 input identities against the actual archive and alerts; preserve the failed attempt. **Limit:** this does not establish continuous delivery or forced-crash recovery. [S03-S04]

3. Replace a suspicious label with a relationship

Problem: R2 depended on the source tagging a successful read as removal-related; the old metadata did not identify the affected member. **Change:** add a closed v2 subject/state assertion, a default-deny signing-key capability, R3 correlation and late-evidence reassessment. **Verification:** test negative boundaries and permission withdrawal, then freeze and evaluate separately. **Limit:** native adapters and group-to-resource mapping still need implementation and proof. [S01-S02]

Tell these as project outcomes unless you personally performed the step. AI coding agents implemented and ran much of this work. Your stronger answer explains why the change addresses the failure, identifies its test and states the remaining limit.

Before an interview, locate one implementation function and one regression test for each story. For story 1: `bridge/services.py` and `tests/test_authorization_refresh.py`. For story 3: `bridge/engine.py` and `tests/test_membership_detection.py`.

What is not finished

Gap	Present status	Evidence needed next
Native R3 instrumentation	Core implemented; no real v2 source adapter enabled.	Reviewed membership/resource semantics, dedicated key authority, real allowed/denied/re-granted/owner tests.
Independent evaluation	All current sets are builder/AI-authored with rule knowledge.	Another author creates scenarios; freeze rules before prospective evaluation; retain all outcomes.
Slow/distributed activity	Known misses in the current detector.	New bounded correlation design plus legitimate traffic controls; measure added noise.
Long-term reliability	Short recovery exercises and a separate-copy backup drill.	Predeclared soak duration/workload, loss/duplicates/backlog/latency, interruptions and recovery.
Broader application coverage	Selected BetTail native paths; Netted portable SQL subset.	Remaining endpoints, signed URLs, real instrumentation and equivalent Netted evidence.
Shuffle SOAR	Images/preparation verified; storage readiness failed. No successful workflow.	Resolve isolated environment compatibility, then verify a bounded review-only workflow.
Production deployment	Local trusted-machine design; current CI file prepared, no new remote run verified.	Threat model, tenancy/identity, operational ownership, backup/retention, load and concurrency, deployment review.
Personal work sample	Reference reviews and coaching exist; human competency is unverified.	Your own analysis, unfamiliar follow-up, external review and an honest assistance record.

Answer the enterprise-comparison question directly

SignalBridge demonstrates patterns relevant to commercial security work: collection, detection, case handling, tool integration and evidence management. It has not been benchmarked against Cortex XSIAM, Wiz, Splunk or equivalent platforms. It does not establish their breadth of data sources, cloud/endpoint coverage, operational scale, availability or support.

An internship using XSIAM or Wiz is separate experience. SignalBridge does not contain a verified live integration with those products. Runtime AI summarization, autonomous containment and broad cloud inventory are not implemented project capabilities.

A credible roadmap is a prioritized measurement plan. Do not add tools merely to expand a logo list. The next integration should answer a specific missing security question within a reviewed scope.

Your ownership and AI disclosure

What the conversation supports

You set the goal, insisted on machine/project safety and approval for consequential changes, requested evidence and auditability, pushed for a usable interface, rejected fictional portfolio material as inadequate, and chose an employer-facing demonstration based on real retained tool evidence. You also identified security analyst learning as a priority. Those are concrete direction and acceptance decisions.

What the evidence does not establish about you

AI coding agents wrote much of the code, implemented tests and documentation, and operated many checks. The receipts prove recorded project behavior; they do not prove that you personally wrote every control, diagnosed every failure, ran each lab manually or independently authored the reference investigations. Your earlier uncertainty about interpreting access evidence is a reason to practice, not something a document can erase.

I led the project scope and acceptance decisions, including safety boundaries and the requirement to show actual integration evidence. AI coding agents produced much of the implementation. I disclose that, and I focus my demonstration on controls and results I can explain and verify. For any component I have not personally modified or investigated, I describe the project's evidence rather than claiming independent authorship.

Resume wording you can substantiate

SignalBridge | AI-assisted access-control monitoring and investigation lab

Directed an AI-assisted security workbench connecting signed application telemetry, scoped analyst workflows and recorded Wazuh/ZAP labs; required evidence-backed claims and explicit safety boundaries.

Project verification recorded 1,102 automated test passes and a 64/64-event Wazuh replay; a separate 22-scenario detection evaluation exposed two misses and two false alerts.

Use stronger personal verbs such as *implemented*, *diagnosed* or *investigated* only for work you actually performed and can defend. Add a personal investigation bullet after completing and reviewing your own report.

Your next hiring advantage is demonstrable understanding: explain the trust boundary, predict a rule outcome, identify a false alert, make a small reviewed change and explain its regression test. Memorized AI answers are not a substitute.

The current runtime is rule-based. 'Built with AI' and 'uses AI to detect threats' are different claims. This guide is also AI-authored and grounded in retained sources.

Recruiter questions: concise answers

What is SignalBridge?

A local access-control monitoring and investigation workbench. It brings signed observations, explicit detections, tool evidence and analyst decisions together. Its purpose is to make a security claim traceable to evidence.

Why did you build it?

To connect application permissions to an actual security workflow and build evidence I could study and explain. BetTail and Netted supplied concrete private-resource use cases. I wanted more than a dashboard or a list of tools.

What is the most impressive working part?

The recorded end-to-end Wazuh handoff is concrete: all 64 records were reconciled against the real tool. I can also show how a failed ZAP scan stays incomplete and how R3 corrects a case when late evidence changes the interpretation.

What did you personally do?

I directed the scope, safety boundaries and evidence requirements, and challenged the presentation until it showed real tool results. AI wrote much of the implementation. I will distinguish that from the analyses and changes I have personally completed.

What would you improve next?

A genuine R3 source adapter, independent evaluation scenarios and measured longer-duration reliability. I would also test changes for slow/distributed detection against legitimate activity to avoid simply increasing noise.

Is it ready for a company to deploy?

It is ready to review as a local proof of concept. A company deployment needs a separate threat model, integration review, operational and scale testing, and accountable ownership. I do not present local test success as production readiness.

How is this relevant to the role?

For analyst roles, it supports evidence interpretation and scoped decisions. For automation or junior engineering roles, it shows contracts, retries, permissions, integration checks and testing. I would demonstrate one workflow that matches the job rather than claim every security specialty.

How long did it take and what impact did it have?

The project and retained development evidence are from September 2026. I have not established an audited personal-hours figure, customer adoption, savings or prevented incidents. I can show the technical deliverables and explain what I learned.

These are answer frameworks. Replace any personal statement with your actual experience; do not imply independent work merely because this guide supplies a fluent answer.

Technical questions: security concepts

Authentication versus authorization?

Authentication establishes identity. Authorization decides whether that identity may perform this action on this resource now. Removing membership need not invalidate the session; the resource check must still reject access.

Why doesn't HTTP 200 alone prove a data leak?

It could contain an empty result, a login page or other non-private content. Confirm the intended identity, known private record, actual returned content and effective permissions. The proposed test requires legitimate-owner and pre-removal controls.

Why isn't 404 or 503 a passing security test?

404 may mean the resource is absent rather than protected; use a known resource and a successful owner control. 503 is a service failure and leaves authorization inconclusive. Keep response semantics separate from a simple status-code check.

What does HMAC protect?

The exact request bytes and signing context are authenticated with a shared secret. It detects modification without that secret. It does not encrypt data, prove the source's business claim or protect against a compromised signing key.

How do you stop replayed data inflating alerts?

Fresh request timestamps bound reuse of an old signature. App/event identity and content digest identify duplicates; a duplicate acknowledgment does not create another event. Reusing an ID with changed content is a conflict.

How do you isolate apps and analyst roles?

The server scopes data and mutations to current app membership. Object IDs or client role values cannot grant access. Write-time permission refresh and version checks address stale authority and stale decisions. Local database administrators remain trusted.

Why are both CSRF and HMAC present?

Browser mutations use session authentication plus CSRF controls. The collector uses explicit signed-request authentication rather than a browser session. They protect different request paths; exempting the signed endpoint from CSRF does not remove its HMAC gate.

Could an insider alter your evidence?

Someone with host/database administration can replace data and hashes. The project records consistency and provenance under that trust boundary, not independently tamper-proof evidence. Stronger assurance needs separate protected evidence storage and operational controls.

Technical questions: engineering choices

Why is R3 better than R2?

R2 relies on a read's suspicious reason label. R3 joins a separately authorized membership assertion to an allowed read using affected subject and exact resource. It adds useful coverage, but missing grants and alternate permissions still require investigation.

Do policy approvals deploy new rules?

No. The Replay lab compares advisory triage policies on labeled synthetic history. Reviewers cannot approve their own proposal, stale evidence is rejected and unsafe retention is blocked. Approval does not replace live R1-R3 or change source permissions.

Does the outbox guarantee no loss?

It retains files until a matching acknowledgment and handles duplicates, retries and interruptions. It is not a transactional source-owned outbox, and power-loss/host-crash losslessness is unproved. A local file append also does not prove Wazuh received it.

What happens when processing fails?

The worker rolls back case/evidence writes, records an error and retry schedule, and eventually retains a dead event. An operator investigates and may requeue reviewed failures. Pending/dead work is not treated as a clean result.

How do you know an integration really ran?

Separate execution receipts bind tool/version, source package, run identity, lifecycle gates and observed results. Wazuh archive/alerts are reconciled with inputs; ZAP receipts separate target outage from a later retry. Merely parsing a report or displaying a logo is insufficient.

Is this scalable and highly available?

Those properties are unproved. SQLite fits a local demonstration; caps and short workloads are bounds, not capacity certifications. I would measure queue age, throughput, latency, loss, duplicates and recovery under a declared workload before designing distributed operation.

Are tests enough to call it secure?

No. They verify selected behaviors, including denial paths and intentionally injected failures. Current datasets are builder-authored. Independent review, native coverage, operational testing and a maintained threat model remain important.

What do you do when you don't know an answer?

State the part you know and the exact limit. Identify the source file or receipt needed, explain the safe check you would perform, and follow up with evidence. Do not invent a capability or turn an unrun check into a passing result.

A seven-minute demonstration

Time	Show	Explain
0:00-0:45	One-sentence purpose	Private access must follow current permissions. AI-assisted project; local proof of concept.
0:45-2:15	portfolio/index.html: Wazuh recorded run	64 inputs, exact observed records, one alert and one non-alert. Explain a rule match and why delivery is not incident confirmation.
2:15-3:00	ZAP failure and separate retry	A failed target gives incomplete coverage, not a clean scan. Three-path passive fixture scope.
3:00-4:30	portfolio/evaluation.html: E01, E18 and E17	Correlated removal, late-grant correction and the missing-context false alert. Show the timeline and evidence counts.
4:30-5:30	Evaluation table and test receipt	6/8 precision, 6/8 recall; two benign false alerts and four inconclusive cases. Separate these from 1,102 test passes.
5:30-6:30	One implementation and regression test	Explain the permission check or correlation condition line by line. Show only code you understand.
6:30-7:00	Limits and next check	Native R3 adapter, independent scenarios, longer reliability test; describe your personal next learning step.

Prepare before the call

Open the two static HTML files locally in a browser and confirm the disclosures/links work. They require no live labs or login. Keep the repository with them, increase zoom if needed and close private credential/log tabs. A recorded video can use the same sequence; label retained evidence and synthetic evaluation accurately.

Do not start Docker, change credentials or attempt an unfamiliar lab recovery during the interview. If a running-console demo is requested, rehearse it beforehand in the correct checkout and use an existing local account. Both checkouts use port 8741; never kill an unidentified listener to make one start.

If the console is unavailable, use the viewer and PDF and label them recorded evidence. Ask which layer the interviewer wants to inspect, then trace one concrete result. If you cannot locate proof, mark the claim unverified and follow up.

What you personally need to do next

Step	Your action	Proof you completed it
1 / 20 minutes	Explain pages 3-7 aloud without reading. Draw the event path and separate authentication from authorization.	A recording or your own diagram; identify where the source can lie and where enforcement happens.
2 / 30 minutes	Compare E01, E17, E18 and E19. Write one analyst note before reading its reference review.	Observation, interpretation, uncertainty and handoff, with exact cited scenario/records and honest assistance disclosure.
3 / 30 minutes	Use the recorded Wazuh or ZAP practice assignment in the correct local console when available. Save and export your submitted note.	Private HTML/JSON export authored by you; not a builder_qa attempt or pasted model answer.
4 / 30-45 minutes	Trace one rule and its test. Predict a boundary outcome, then verify it in disposable tests with guidance if needed.	Your prediction, observed result and explanation of any disagreement. No live permission change is required.
5 / reviewer session	Ask a mentor or security practitioner to challenge your note and demo. Share only a reviewed, sanitized copy.	Their actual feedback, your revision and one remaining uncertainty. Do not fabricate independent review.
6 / 10-minute rehearsal	Deliver the seven-minute walkthrough and answer two unfamiliar follow-ups.	You can locate evidence, explain a false alert and state a limit without relying on a script.

Private work-sample template

Evidence: Which run and records did I inspect? **Observation:** What do they directly show? **Interpretation:** Which requirement might be affected? **Alternative:** What benign or failed-service explanation remains? **Handoff:** Who should do what safe check, and what result would resolve it? **Assistance:** What AI/human help and prior exposure did I have?

Your readiness check

You are ready to defend this project when you can explain the architecture and trust boundary, distinguish an alert from a confirmed finding, calculate the metric denominators, show one tested correction, disclose AI involvement and respond honestly to an unknown. No document can guarantee readiness for every question.

First action today: write your own E18 note in four short paragraphs. Explain why the initial alert was reasonable, what changed, why history must remain and which next check belongs to the application owner.

Terms, files and operating boundaries

Term	Plain-language meaning here
Telemetry / provenance	Recorded observations / where they came from and which execution or source they are bound to.
Pseudonym	A scoped substitute identifier. It reduces direct disclosure but is not guaranteed anonymous.
Correlation	Joining observations by defined identities, resource and time rather than treating each event alone.
Idempotent	Repeating the same operation does not create another logical result; identical event imports are an example.
Positive / negative control	A condition expected to succeed / one expected to be rejected or not alert. Both help interpret failures.
False positive / false negative	An alert on declared benign activity / no alert on declared suspicious activity, within the defined evaluation unit.
RLS / JWT	Row-level security constrains visible database rows; a JSON Web Token carries signed identity/claims. Valid identity does not automatically authorize a resource.
SARIF / SIEM / SOAR	A structured analysis-report format / security-event collection and investigation / workflow automation. Format support is not a complete product integration.
Replay / holdout / drift	Re-evaluating retained inputs / separate evaluation data / evidence or source changing relative to the recorded identity.

Where to inspect code

Trust: bridge/contract.py, ingestion.py, services.py. **Detection:** engine.py, worker.py, detection_catalog.py. **Proof:** case_provenance.py, scripts/evaluate_detection.py, fixtures/detection_evaluation/. **Integrations:** integrations/sender.mjs, integrations/wazuh/, bridge/scanner_reports.py. **Analyst practice:** bridge/practice.py, recorded_practice.py.

Operate deliberately

The README's setup creates a project environment; demo-core applies local migrations, creates accounts and adds synthetic data. It is not a read-only viewer command. The new R3 migration has not been applied to the older working app. Do not use a different checkout's startup command against the same occupied port.

For a prepared checkout, scripts/sb.py up/down manage its identified loopback console; down preserves data and does not stop Docker labs. The frozen evaluation runs with memory-only SQLite and writes a new local receipt. Do not overwrite its freeze/declaration to make changed rules appear previously evaluated.

Installations, new downloads, migrations, credential grants, public hosting and native lab operations require the appropriate reviewed scope. This guide authorizes none of them and changes no machine service. [S11-S12]

Evidence index and scope of this handoff

Source references below point into the public checkout. Open the named receipt to inspect its exact run identity, hashes, counts and limitations. Source evidence was reviewed for this document; the historical labs and full test suite were not rerun to create the PDF.

S01 | Latest local software verification

[docs/evidence/20260929T234005261035Z-7f0549f8.json](#)

S02 | Frozen membership detection evaluation

[docs/evidence/20260929-membership-evaluation.json](#)

S03 | Native Wazuh backfill and collection

[docs/evidence/20260925-wazuh-product-backfill.json](#)

S04 | Native Wazuh collector recovery

[docs/evidence/20260925-wazuh-collector-recovery.json](#)

S05 | ZAP outage, retry and import checks

[docs/evidence/20260925-zap-repeat-failure.json](#)

S05b | Later ZAP console import

[docs/evidence/20260925-zap-console-import.json](#)

S06 | Genuine BetTail route/service evidence

[docs/evidence/20260924-bettail-next-routes.json](#)

S07 | Approved lab repair and scoped retest

[docs/evidence/20260925-bettail-hardening-complete.json](#)

S08 | Separate-copy database/delivery restore

[docs/evidence/20260925-local-backup-restore.json](#)

S09 | Historical challenge and unmet probes

[docs/evidence/20260926-challenge-6ddeb3098b4845cbb29fc072d59056f6.json](#)

S09b | Historical development scenarios

[docs/evidence/20260926-simulation-cbf23a2222b6459cafd84af7d29aa4a5.json](#)

S10 | Permission-refresh defect and regression

[docs/evidence/20260925-authorization-refresh.json](#)

S11 | Current design and limitations

[docs/DESIGN.md](#)

S12 | Setup, scope and security boundary

[README.md](#)

What was verified for this document

Current source and documentation were inspected, key counts were reconciled with receipts, and the latest source manifest was compared with its verification record. The PDF's text, page layout, internal navigation and references were checked. No publication, paid service, lab startup, production access or application migration was performed.

The document is a consolidated personal handoff, not a log of every tool call. It covers implemented workflows, material experiments, failures, security corrections and unfinished scope relevant to interviews. Historical records remain the authority for their own executions; current code describes current implemented behavior.

Before you reuse a claim: identify the date, environment, denominator, source and limit. If any of those is missing, narrow the claim or verify it before presenting it.